

INF-19a Chráním digitální zařízení a digitální obsah před poškozením či zneužitím s vědomím změn v technologiích, které ovlivňují bezpečnost.

Na test máš 30 minut. Pracuj samostatně, bez pomoci druhých i umělé inteligence. Povolena je kalkulačka (nebo Python jako kalkulačka). Škola v testu používá smyšlenou doménu skola.example, všechny zprávy a adresy jsou vymyšlené. Do odpovědí nikdy nepiš svá skutečná hesla ani kódy. Odpovědi zapiš do dokumentu nebo na papír a nahraj je do portfolia na Google Disku.

- Pojmenuj typ útoku (virus, červ, trojský kůň, ransomware, spyware, phishing, smishing, vishing, credential stuffing): a) po otevření přílohy „rozvrh.pdf.exe“ program tajně zaznamenává, co píšeš na klávesnici; b) telefon hlásí, že data jsou zašifrována a odemknou se po zaplacení; c) útočník zkouší na tvém školním účtu hesla, která unikla z jiné služby; d) volá ti „technická podpora“ a chce vzdálený přístup k počítači; e) program se sám šíří sítí na počítače bez aktualizací; f) SMS: „Balík čeká na doplacení 29 Kč“ s odkazem.
- Najdi v e-mailu aspoň pět varovných znaků. Co uděláš, a) když ho dostaneš, b) když už jsi na odkaz klikl a zadal heslo?

Od: Správa školního Disku <podpora@skola-disk-overeni.example>
Předmět: Úložiště plné – portfolio bude SMAZÁNO!

Ahoj,
tvoje úložiště překročilo limit. Do 12 hodin automaticky smažeme všechny soubory ve tvém portfoliu. Pro zachování dat se ihned přihlas
a ověř účet: <https://disk.skola.example.overeni-uctu.example/login>

Tým podpory

- Skutečná doména tvé školy je skola.example. Které odkazy opravdu vedou na školní server? Zdůvodni. a) <https://prihlaseni.skola.example/portfolio>; b) <https://skola.example.prihlaseni.example/>; c) <https://skola-example.com/login>; d) <https://skola.example@203.0.113.7/login>; e) <http://skola.example/rozvrh>
- Útočník získal uniklou databázi otisků hesel a zkouší 10^{10} hesel za sekundu. Spočítej počet možností, sílu v bitech a nejdelší dobu prolomení pro náhodně zvolené heslo: a) 10 malých písmen (26 znaků); b) 8 znaků z 95; c) 5 slov náhodně vylosovaných ze seznamu 7 776 slov. Proč heslo „Portfolio2026!“ není tak silné, jak by odpovídalo 14 znakům z 95?
- Máš zapnuté dvoufaktorové ověření kódem z SMS. Zavolá ti „banka“, že ti posílá kód ke zrušení podezřelé platby, a chce, abys ho nadiktoval. Proč to nesmíš udělat? Které druhé ověření by odolalo i podvodné přihlašovací stránce a proč?
- Portfolio máš jen ve složce na notebooku, která se synchronizuje na Google Disk. Splňuje to pravidlo 3-2-1? Co se stane při a) krádeži notebooku, b) útoku ransomwaru, který soubory v notebooku zašifruje, c) omylem smazané složce? Navrhni plán zálohování. Kolik potrvá první záloha 120 GB na externí disk rychlostí 80 MB/s a kolik do cloudu při rychlosti odesílání 20 Mb/s?
- Změny v technologiích: a) Tvůj telefon už dva roky nedostává bezpečnostní aktualizace, ale funguje. Proč je to riziko a co s tím můžeš dělat? b) Jak umělá inteligence mění podvodné zprávy a hovory a co z toho plyne pro tvou obranu?
- Kupuješ nový notebook na online školu. Navrhni kontrolní seznam aspoň šesti kroků zabezpečení v rozumném pořadí a u každého napiš, proti čemu chrání.

Test slouží k doložení výstupu do portfolia. Nehodnotí se body ani známkou – rozhoduje, jestli splníš kritéria na konci dokumentu.

1. **a) trojský kůň, který nainstaluje spyware (keylogger); b) ransomware; c) credential stuffing; d) vishing (sociotechnika po telefonu); e) červ; f) smishing (phishing přes SMS).** – ověřuje: rozpoznání běžných typů útoků a sociotechnických metod
2. **Znaky: odesílatel z cizí domény (skola-disk-overeni.example, ne skola.example); naléhavost a hrozba (12 hodin, SMAZÁNO); obecné oslovení; výzva přihlásit se přes odkaz; odkaz ve skutečnosti vede na doménu overeni-uctu.example (skola.example je jen začátek adresy); škola by nemazala portfolio bez oznámení. a) Neklikat, otevřít Disk sám (záložkou nebo ručně napsanou adresou) a stav úložiště zkontrolovat; zprávu nahlásit jako phishing a upozornit učitele nebo správce. b) Ihned změnit heslo (a všude, kde bylo stejné), zkontrolovat nebo zapnout dvoufaktorové ověření, odhlásit cizí relace, nahlásit správci.** – ověřuje: rozpoznání phishingu a správná reakce na něj i na už prozrazené heslo
3. **a) ano (subdoména skola.example); b) ne – doména je prihlaseni.example; c) ne – úplně jiná doména; d) ne – vše před @ je jen jméno uživatele, cílem je server 203.0.113.7; e) doména ano, ale spojení http není šifrované – heslo tam nezadávej.** – ověřuje: čtení skutečné domény v adrese jako obrana proti podvodným odkazům
4. **a) $26^{10} \doteq 1,4 \cdot 10^{14}$, 47 bitů, asi $1,4 \cdot 10^4 \text{ s} \approx 3,9 \text{ h}$; b) $95^8 \doteq 6,6 \cdot 10^{15}$, asi 53 bitů, $6,6 \cdot 10^5 \text{ s} \approx 7,7 \text{ dne}$; c) $7776^5 \doteq 2,8 \cdot 10^{19}$, asi 65 bitů, $2,8 \cdot 10^9 \text{ s} \approx 90 \text{ let}$. „Portfolio2026!“ není náhodné – slovo, rok a vykřičník jsou přesně to, co zkouší slovníkové útoky, takže útočník ho najde mnohem dřív.** – ověřuje: posouzení síly hesla výpočtem a pochopení rozdílu mezi délkou a náhodností
 1. $N = k^n$: $26^{10} \doteq 1,41 \cdot 10^{14}$; $95^8 \doteq 6,63 \cdot 10^{15}$; $7776^5 \doteq 2,84 \cdot 10^{19}$.
 2. Bity $b = \log_2 N$: 47,0; 52,6; 64,6.
 3. Doba $t = \frac{N}{10^{10}}$: $1,4 \cdot 10^4 \text{ s} \doteq 3,9 \text{ h}$.
 4. $\frac{6,6 \cdot 10^5 \text{ s}}{86400 \text{ s}} \doteq 7,7 \text{ dne}$.
 5. $\frac{2,8 \cdot 10^9 \text{ s}}{86400 \cdot 365 \text{ s}} \doteq 90 \text{ let}$.
 6. Vzorec platí jen pro náhodná hesla; předvídatelné heslo je ve slovníku útočníka.
5. **Kód je druhý faktor – útočník, který už zná heslo nebo údaje, se jím přihlásí nebo potvrdí platbu; banka kód nikdy nechce. Hovor ukonči a zavolej bance sám na číslo z karty nebo webu. Odolnější je bezpečnostní klíč nebo passkey (standard FIDO2): ověřují adresu webu, takže na podvodné doméně nefungují a nedá se nic nadiktovat.** – ověřuje: pochopení vícefaktorového ověření a jeho obcházení sociotechnikou
6. **Nesplňuje – synchronizace není záloha (2 kopie, ale změny a smazání se přenesou). a) data zůstanou v cloudu; b) zašifrované soubory se synchronizují do cloudu – pomůže jen historie verzí, pokud ji služba má; c) smazání se přenesou i do cloudu (zbude jen koš na omezenou dobu). Plán: 3 kopie (notebook, cloud, externí disk), 2 druhy médií, 1 mimo domov; externí disk připojovat jen při záloze (např. týdně), občas vyzkoušet obnovu. Externí disk: $1\,500 \text{ s} = 25 \text{ min}$; cloud: $48\,000 \text{ s} \approx 13,3 \text{ h}$.** – ověřuje: návrh zálohování podle pravidla 3-2-1 a rozlišení zálohy a synchronizace
 1. Synchronizace drží stejný stav na obou místech – smazání i zašifrování se zkopíruje.
 2. Záloha je nezávislá kopie s historií, ideálně odpojená od počítače.
 3. Externí disk: $\frac{120\,000 \text{ MB}}{80 \text{ MB/s}} = 1\,500 \text{ s} = 25 \text{ min}$.
 4. Cloud: $120 \text{ GB} = 120 \cdot 8 \cdot 10^9 \text{ b} = 9,6 \cdot 10^{11} \text{ b}$.
 5. $t = \frac{9,6 \cdot 10^{11}}{2 \cdot 10^7} = 48\,000 \text{ s} \doteq 13,3 \text{ h}$.
7. **a) Nově objevené zranitelnosti se už neopraví a útočníci je znají (záplaty jiných zařízení je prozradí); řešení: nepoužívat ho na bankovníctví a důležité účty, aktualizovat aspoň aplikace, zvážit výměnu nebo systém s podporou. b) AI píše bezchybné a osobně laděné zprávy a napodobí hlas či video (deepfake) – chyby v češtině už nejsou spolehlivý znak; obrana: ověřovat žádosti jiným kanálem (zavolat na známé číslo), dohodnout si kontrolní otázku, nespěchat, používat odolné druhé ověření.** – ověřuje: vědomí změn v technologiích, které ovlivňují bezpečnost

8. Např.: 1) aktualizovat systém a zapnout automatické aktualizace – známé zranitelnosti; 2) účet s PINem nebo heslem a zámek obrazovky (biometrie) – přístup cizího člověka; 3) šifrování disku – únik dat při krádeži; 4) zapnutý antivir a firewall – malware a nechtěná síťová spojení; 5) správce hesel, různá hesla a dvoufaktorové ověření u e-mailu a školního účtu – prolomení účtů; 6) záloha podle 3-2-1 a zkouška obnovy – ztráta dat, ransomware; 7) programy jen z oficiálních zdrojů – trojské koně. – ověřuje: systémový přístup k zabezpečení zařízení a dat

Kritéria splnění výstupu

- Správně pojmenuje aspoň 5 z 6 útoků (úloha 1) a u phishingu najde aspoň čtyři varovné znaky včetně skutečné domény odkazu a popíše správnou reakci i po prozrazení hesla (úlohy 2 a 3).
- Spočítá sílu náhodných hesel (počet možností a dobu prolomení) a vysvětlí, proč předvídatelné heslo tomuto výpočtu neodpovídá (úloha 4).
- Vysvětlí, jak funguje a jak se obchází vícefaktorové ověření, a navrhne zálohování podle pravidla 3-2-1, které odolá krádeži, ransomwaru i smazání (úlohy 5 a 6).
- Navrhne ucelený kontrolní seznam zabezpečení zařízení s vysvětlením, proti čemu který krok chrání, a zohlední změny technologií – konec podpory, AI v podvodech (úlohy 7 a 8).

Pro učitele: varianty a přizpůsobení

Obměny: jiný podvodný e-mail (výhra, faktura, sdílený dokument), jiné délky hesel a rychlost útoku (10^9 nebo 10^{12} pokusů/s), jiný objem zálohy. Praktická varianta místo úlohy 8: Žák doloží do portfolia kontrolní seznam svého skutečného zařízení (bez hesel a čísel), třeba snímky nastavení aktualizací a zálohy. Úlohu 2 lze dělat v Meetu nad sdíleným obrázkem v Excalidraw, kde žák varovné znaky zakroužkuje. Pro 1. ročník lze úlohu 4 zjednodušit na porovnání dvou hesel. Kratší verze: úlohy 2, 4, 6 a 8.

Výstup se probírá v lekcích: 1.+2. H61 Bezpečnost zařízení a dat (týden 31)